

Chương 5. Blockchain trên cơ chế bộ ba an ninh của CIA

Mục tiêu bài học

- Tìm hiểu về khái niệm bộ ba an ninh của CIA
- Cách ba yếu tố cốt lõi CIA tác động đến công nghệ Blockchain
- Cách tổ chức sử dụng Blockchain tối ưu với mô hình bảo mật CIA.

Nội dung bài học

- Khái niệm bộ ba an ninh của CIA
- Blockchain và tính bảo mật
- Blockchain và tính toàn vẹn
- Blockchain và tính sẵn sàng

1. Khái niệm bộ ba an ninh của CIA

- CIA là một khuôn khổ / mô hình được sử dụng để sắp xếp một danh sách các kiểm soát an ninh và hệ thống được sử dụng bởi nhóm bảo mật thông tin (infosec).
- Nó còn được gọi là bộ ba bảo mật AIC - Availability, Integrity, Confidentiality.
- Mục đích của CIA là cung cấp một khuôn khổ tiêu chuẩn để đánh giá và triển khai các chính sách bảo mật thông tin, độc lập với công nghệ, hệ thống mạng và hệ thống cơ bản.

1.1. Tính bảo mật (Confidentiality)

- Bảo mật là cách để giữ thông tin ẩn từ những người không được phép.
- Khi thông tin phải được bảo mật vẫn là một bí mật, bạn sẽ đạt được tính bảo mật.
- Trong thời đại hiện nay, mọi người đều cần thông tin được giữ bí mật.
- Tổ chức bảo mật là một ví dụ điển hình của một tổ chức phá vỡ bí mật để họ có thể thực hiện pháp y và theo dấu tội phạm.
- Có một cuộc đua không bao giờ kết thúc giữa tin tặc và chuyên gia bảo mật.
- Các tổ chức đang chi hàng triệu đô la mỗi năm để đạt được bảo mật đa tầng với mật mã và hệ thống kiểm soát truy cập.

1.2. Tính toàn vẹn (Integrity)

- Tính toàn vẹn là cách để bảo vệ việc giả mạo thông tin trái phép.
- Là một sự tuân thủ bắt buộc cho mỗi nhóm bảo mật thông tin infosec.
- Là một phương pháp để duy trì tính nhất quán, chính xác và đáng tin cậy của dữ liệu tương ứng trong toàn bộ vòng đời của nó.
- Điều quan trọng là phải đạt được bảo mật dữ liệu hoàn toàn và bất kỳ truy cập dữ liệu trái phép đều bị cấm.
- Một số biện pháp hỗ trợ bao gồm quyền tập tin và kiểm soát truy cập người dùng.

1.2. Tính sẵn sàng (Availability)

- Tính sẵn sàng liên quan đến quyền truy cập dữ liệu theo thời gian và đáng tin cậy.
- Đường đi từ dữ liệu đến thông tin và từ thông tin đến giá có ý nghĩa là giá trị sẽ không hợp lệ nếu thông tin không có sẵn vào đúng thời điểm.
- Các cuộc tấn công DDoS và ransomware là những vũ khí mạnh nhất được sử dụng để làm tê liệt nhu cầu truy cập thông tin từ người dùng hợp lệ nhằm gây thiệt hại cho doanh nghiệp.
- Các tổ chức đã nỗ lực chống lại các cuộc tấn công này bằng các giải pháp tường lửa ứng dụng web, bảo vệ DDoS, mạng phân phối nội dung (CDN) và khôi phục sau thảm họa.

2. Blockchain và tính bảo mật

- Mỗi công nghệ kỹ thuật số đều đi kèm với những thách thức bảo mật như quyền riêng tư, xâm nhập bảo mật, trộm cắp định danh...
- Blockchain là công nghệ điện toán chạy trên một hệ sinh thái kỹ thuật số. Vì vậy, cần chú ý đến những thách thức bảo mật cơ bản của nó.
- Các doanh nghiệp trên thế giới đều phân bổ ngân sách hàng năm cho an ninh mạng để giữ bí mật thông tin và tài sản quan trọng của mình.

2.1. Tính bảo mật trong mô hình hiện có

- Bảo mật đối với Blockchain chỉ đơn giản là che giấu thông tin giao dịch từ những người tham gia ẩn danh trong mạng.
- Tuy nhiên, đối với những Blockchain mở như Bitcoin, việc đạt được tiêu chuẩn bảo mật tốt hơn sẽ rất khó khăn.

2.2. Doanh nghiệp, Blockchain và bảo mật

- Trong DN, bảo mật trở thành một trụ cột quan trọng trong an ninh mạng để đạt được sự tin tưởng tốt hơn giữa khách hàng và các bên liên quan khác.
- Blockchain được cấp phép đã được đánh giá cao vì nó chỉ cho phép những người được chọn truy cập dữ liệu trong mạng sổ cái phân tán.
- Khi một doanh nghiệp kết nối với một doanh nghiệp khác, ngoài việc xem xét những thông tin nào có thể chia sẻ, cũng cần phải xem xét những người cần phải có quyền truy cập vào thông tin trong những điều kiện nhất định.

2.2. Doanh nghiệp, Blockchain và bảo mật

- Trong khi xem xét Hyperledger Fabric, IBM gợi ý một số điểm cần lưu ý:
 - Với mỗi giao dịch, điều quan trọng là phải biết liệu người tham gia có thể xem thông tin đầy đủ hoặc một phần của nó hay không. Nó phải được đề cập theo một hợp đồng thông minh.
 - Nếu đã chỉ định tổ chức quản lý thì họ phải xác nhận mức độ dữ liệu được truy cập bởi tổ chức quản lý.
 - Phải hiểu bản chất của hệ thống mạng của bạn - tĩnh hoặc động - vì các thông số bảo mật có thể thay đổi trong tương lai, dựa trên vai trò và nhu cầu mới của người tham gia.

2.3. Đạt được tính bảo mật với Hyperledger Fabric

- **Kiểm soát truy cập dựa trên thuộc tính (Attribute Based Access Control -ABAC):**
 - Quyết định của người dùng truy cập giao dịch phụ thuộc vào định danh của giao dịch, có thể thực hiện với ABAC. ABAC có thể hỗ trợ cả chaincode và toàn bộ fabric.
 - Các thuộc tính được sử dụng trong quá trình triển khai giao dịch phải được thông qua trong quá trình tạo Tcert bởi người dùng. Đây là bước quan trọng để xác định xem người dùng có thể thực hiện chaincode.
 - Tổ chức cấp giấy chứng nhận thuộc tính Attribute Certificate Authority (ACA) đóng vai trò quan trọng trong việc xác nhận thuộc tính và trả về chứng chỉ thuộc tính (ACert). ACA duy trì CSDL để các doanh nghiệp có thể lưu trữ các thuộc tính cho người dùng và chi nhánh của họ.

2.3. Đạt được tính bảo mật với Hyperledger Fabric

- **Ngôn ngữ mã hóa Hyperledger Fabric:**

- Hợp đồng thông minh có thể được cấu hình để mã hóa thông tin hoặc một tập con thông tin trong giao dịch.
- Thông tin này vẫn được mã hóa trong sổ cái với khóa chỉ có sẵn cho những peer đề nghị xem và truy cập nó.
- Nếu chính sách chứng thực cần peer từ các tổ chức khác nhau, thì thông tin phải được mã hóa trước khi đưa nó vào đề xuất giao dịch.

3. Blockchain và tính toàn vẹn

- Nhiều tổ chức vẫn miễn cưỡng sử dụng các giải pháp cloud công cộng, ngay cả khi đã chi nhiều tiền hơn cho an ninh mạng.
- Việc áp dụng mã hóa dữ liệu đưa lên cloud chỉ có thể cung cấp bảo mật vững chắc chống lại các cuộc tấn công nội bộ chứ không thể bảo vệ dữ liệu khỏi bị hỏng gây ra bởi lỗi cấu hình, lỗi phần mềm hoặc nỗ lực gián điệp.
- Công nghệ Blockchain có cách tiếp cận vững chắc riêng để đạt được sự toàn vẹn với thuật toán băm và sự toàn vẹn với mô hình cây Merkle.
- Việc triển khai Blockchain trên thực tế với các ứng dụng trong thế giới thực sẽ là một thách thức lớn cho công nghệ này.

3.1. Tính toàn vẹn trong mạng Blockchain hiện nay

- Blockchain sử dụng băm mật mã để đảm bảo rằng số cái sẽ phòng tránh được sự giả mạo.
- Chức năng băm trong Blockchain là một chiều, có nghĩa là về mặt logic, ta không thể có được dữ liệu trở lại từ kết quả băm hoặc từ thông điệp rút gọn.
- Rất khó để phân tích các mô hình của thông điệp rút gọn và dự đoán các dữ liệu ban đầu, ngay cả một sự thay đổi nhỏ trong thông điệp thực tế có thể dẫn đến một sự khác biệt lớn.
- Tất cả các công nghệ của Blockchain sử dụng băm phổ biến sau:
 - Mã định danh tài khoản Ethereum được tạo bằng cách băm khóa công khai bằng thuật toán băm Keccak-256
 - Địa chỉ Bitcoin được tính bằng cách băm khóa công khai bằng thuật toán SHA-256

3.2. Sắp xếp khối và toàn vẹn

Mỗi nút lưu trữ sổ cái dưới dạng các khối được kết nối và việc tạo ra một khối mới phụ thuộc vào băm của khối trước đó. Điều này giúp:

- Ngăn chặn tin tặc phá hoại, thay đổi hoặc xóa bất kỳ khối nào trong sổ cái.
- Các tổ chức đạt được một cấp độ mới về tính toàn vẹn an ninh mạng và cung cấp một nền tảng có thể phát triển một ứng dụng doanh nghiệp chống giả mạo.

3.3. Tính toàn vẹn với Hyperledger

Mặc dù Hyperledger Fabric là một trong những phiên bản của công nghệ sổ cái phân tán nhưng có một số khác biệt quan trọng:

- Việc cam kết một peer luôn luôn xác nhận khối mới trước khi thêm nó vào sổ cái.
- Khi một peer bị tấn công có nghĩa là khối có thể bị xâm nhập từ sổ cái. Để tránh tình huống như vậy, có một số phương pháp được đưa ra để sửa cách một khối được thêm vào sổ cái.

3.4. Xác minh tính toàn vẹn của chuỗi

- Trong phương pháp này, mỗi peer xác thực Blockchain của nó định kỳ và yêu cầu peer kiểm tra lại xem có phát hiện được khối nào bị hỏng hay không. Một hàm có tên CheckChainIntegrity() được gọi để giữ cho kiểm tra tính toàn vẹn đang thực thi:

```
// Periodically checks the integrity of the block chain on this peer
func CheckChainIntegrity() {
    var l ledger.PeerLedger
    blockChainInfo, err := l.GetBlockchainInfo()
    quit := make(chan struct{})

    for {
        select {
        case <- time.After(600*time.Second): //check the integrity of the blockchain every 10 minutes
        case <- quit:
            return
        }

        for k, v := range chains.list {
            l = v.cs.ledger
            ledgermgmt.VerifyChain(k, l, 0, blockChainInfo.Height)
        }
        break
    }
}
```

4. Blockchain và tính sẵn sàng

- Các ứng dụng doanh nghiệp có thể truy cập thông qua các mạng (mở hay đóng), và các ứng dụng này là tập code có giá trị cho đến khi chúng có thể truy cập được khi cần.
- Blockchain là một ứng dụng phần mềm chạy trên cloud đảm bảo tính sẵn sàng rất tốt trước những cuộc tấn công phá hoại.
- Đối với người dùng, Blockchain chỉ đơn giản là một ứng dụng phân tán (dApp), và để giữ cho nó luôn có sẵn mọi lúc, cả việc tiếp nhận và xử lý của hệ thống cũng luôn đảm bảo tính liên tục.

4.1. Tính sẵn sàng trong mạng Blockchain hiện nay

- Các cuộc tấn công mạng như DDoS gây ra sự gián đoạn rất lớn đối với các dịch vụ Internet và ngăn cản người dùng tiếp cận các trang web, khiến các doanh nghiệp tổn rất nhiều tiền.
- Bản chất phân tán của Blockchain làm cho việc tấn công mạng nhằm phá vỡ các ứng dụng này trở nên khó khăn hơn.

4.2. Xác suất thất bại của hệ thống là zero

- Ngay cả khi một nút trong Blockchain bị offline, thông tin có thể được truy cập và sử dụng bởi phần còn lại của các nút trong mạng.
- Vì tất cả các nút giữ một bản sao chính xác của sổ cái nên thông tin sẽ luôn được cập nhật. Tất cả các nút trong mạng được phân cấp một cách hợp lý từ sổ cái, và xác suất thất bại của hệ thống là zero.

4.3. Doanh nghiệp và tính sẵn sàng

- Với Blockchain, tính sẵn sàng được xác định bởi các giao dịch hợp lệ và thành công.
- Đối với mỗi doanh nghiệp, việc lưu giữ hồ sơ của tất cả các giao dịch là một chức năng cốt lõi
- Các giao dịch này có thể là một danh mục trong hoạt động doanh nghiệp, danh mục tài sản, hồ sơ quản lý chuỗi cung ứng và nhiều giao dịch khác.

5. Kết luận

- Trong chương này, chúng ta đã nghiên cứu tác động của bộ ba bảo mật CIA đối với công nghệ Blockchain.
- Mặc dù Blockchain Bitcoin đủ mạnh để đảm bảo khuôn khổ bảo mật của CIA, nó được đánh giá cao và được thông qua bởi một số tổ chức, và một số ứng dụng của Blockchain đang được giới thiệu với thị trường để đổi mới các mô hình doanh nghiệp.
- Chúng ta đã hiểu được Hyperledger Fabric thật sự phù hợp với bộ ba an ninh của CIA và cách làm cho hệ thống Hyperledger Fabric trở thành một giải pháp thân thiện với doanh nghiệp.

